

Encuesta COBIT 2019 de Ciberseguridad y Gobierno de TI

Aplicación empresarial (España) con enfoque comparativo internacional

Versión 1.0 – Inspirada en COBIT 2019 y marcos de ciberseguridad alineados con estándares internacionales.[web:18][web:39]

Uso recomendado: empresas y organismos de tamaño medio y grande, especialmente sectores regulados y críticos.[web:24][web:44]

0. Datos generales de la organización

0.1. Sector principal de actividad

- ☐ Administración Pública
- ☐ Energía / Utilities
- ☐ Sanidad
- ☐ Financiero / Seguros
- ☐ Industria / Manufactura
- ☐ Telecomunicaciones / Tecnología
- ☐ Transporte / Logística
- ☐ Otros (especificar): _____

0.2. Tamaño aproximado (empleados)

- ☐ < 50
- ☐ 50 – 249
- ☐ 250 – 999
- ☐ 1.000 – 4.999
- ☐ ≥ 5.000

0.3. Alcance geográfico

- ☐ Solo ámbito local / regional
- ☐ Nacional
- ☐ Unión Europea
- ☐ Internacional (fuera de UE)

0.4. Rol del encuestado

- ☐ CISO / Responsable de Seguridad
- ☐ CIO / Director de TI
- ☐ Responsable de Riesgos / Compliance
- ☐ Dirección General / Consejo
- ☐ Otro (especificar): _____

1. Gobierno y optimización del riesgo (EDM03)

Objetivo COBIT relacionado: **EDM03 – Ensured Risk Optimization**. [web:34][web:27]

1.1. Supervisión de la ciberseguridad por el órgano de gobierno

P1.1.1 ¿Con qué frecuencia revisa el máximo órgano de gobierno (Consejo, Comité de Dirección, equivalente) la información estructurada de ciberseguridad (indicadores, riesgos, planes)?

- ☐ Nunca; la ciberseguridad es un rumor de pasillo.
- ☐ Solo en caso de incidente grave (cuando el fuego ya es visible).
- ☐ Al menos una vez al año.
- ☐ Trimestralmente.
- ☐ Mensualmente o más frecuente.

P1.1.2 El órgano de gobierno dispone de **informes de ciberseguridad** con objetivos, métricas y brechas claramente definidos.

- ☐ No dispone de informes formales.
- ☐ Informes ad hoc y reactivos, sin estructura repetible.
- ☐ Informes anuales o puntuales, con algunos indicadores básicos.
- ☐ Informes periódicos (trimestrales) con objetivos y métricas definidos.
- ☐ Cuadro de mando integrado con objetivos, métricas y tendencias, revisado regularmente.

1.2. Apetito y tolerancia al riesgo

P1.2.1 ¿Cuenta su organización con una **declaración formal de apetito y tolerancia al riesgo de ciberseguridad**?

- ☐ No, las decisiones se basan en el “olfato” directivo.
- ☐ Sí, pero no está documentada; todos “saben” cuál es (más o menos).
- ☐ Sí, documentada; se consulta ocasionalmente.
- ☐ Sí, documentada y usada de forma sistemática para priorizar inversiones.
- ☐ Sí, integrada en procesos de inversión, de aprobación de proyectos y de reporting.

P1.2.2 El apetito al riesgo se **revisa y actualiza**:

- ☐ Nunca; se definió una vez y ahí quedó.
- ☐ Solo tras incidentes significativos.
- ☐ Al menos cada 3 años.
- ☐ Al menos cada 2 años.
- ☐ Anualmente o con mayor frecuencia.

2. Gestión del riesgo de TI (APO12)

Objetivo COBIT relacionado: **APO12 – Managed Risk**. [web:14][web:24]

2.1. Proceso formal de gestión de riesgos

P2.1.1 ¿Dispone su organización de un **proceso formal de gestión de riesgos de TI/ciberseguridad**?

- ☐ No existe ningún proceso definido.
- ☐ Existen prácticas dispersas, sin proceso unificado.
- ☐ Existe un proceso definido, pero se aplica de forma irregular.
- ☐ Proceso definido y aplicado de forma sistemática en proyectos relevantes.
- ☐ Proceso plenamente integrado y alineado con riesgos corporativos.

P2.1.2 En la práctica, el proceso de gestión de riesgos cubre:

- ☐ Solo riesgos técnicos de TI aislados.
- ☐ Riesgos técnicos, con cierto enlace al riesgo operativo.
- ☐ Riesgos de TI y su impacto en procesos de negocio clave.
- ☐ Riesgos de TI, negocio, reputación, cumplimiento y terceros.
- ☐ Cobertura integral, alineada con el mapa de riesgos corporativo.

2.2. Cobertura de activos y frecuencia de análisis

P2.2.1 Porcentaje aproximado de **activos críticos** (sistemas, aplicaciones, datos) con análisis de riesgos completado o actualizado en los últimos 12 meses.

- ☐ 0 – 20 %
- ☐ 21 – 40 %
- ☐ 41 – 60 %
- ☐ 61 – 80 %
- ☐ 81 – 100 %

P2.2.2 Frecuencia típica de revisión de los análisis de riesgos de sistemas críticos:

- ☐ Solo tras incidentes o auditorías.
- ☐ Cada 3 años o más.
- ☐ Cada 2 años.
- ☐ Anual.
- ☐ Semestral o más frecuente.

3. Seguridad gestionada (APO13 – SGSI)

Objetivo COBIT: **APO13 – Managed Security**. [web:24][web:35]

3.1. Existencia y alcance del SGSI

P3.1.1 ¿Cuenta su organización con un **Sistema de Gestión de Seguridad de la Información (SGSI)**?

- ☐ No existe SGSI; hay controles dispersos.
- ☐ Existe un conjunto de políticas sin un SGSI formal.
- ☐ SGSI definido y parcialmente implantado (algunos procesos clave).
- ☐ SGSI implantado y operativo a nivel organizativo principal.
- ☐ SGSI consolidado, integrado con gestión de riesgos, continuidad y cumplimiento.

P3.1.2 Respecto a **ISO 27001 u otros estándares**:

- ☐ No hay alineamiento explícito.
- ☐ Referencia informal a ISO 27001 sin certificación.
- ☐ Alineamiento formal, sin certificación.
- ☐ Certificación ISO 27001 parcial (algunos procesos/ubicaciones).
- ☐ Certificación ISO 27001 amplia (mayor parte de la organización).

3.2. Función de seguridad y recursos

P3.2.1 ¿Dispone la organización de una **función de seguridad definida** (CISO o equivalente)?

- ☐ No existe; seguridad es “cosa de TI”.
- ☐ Un responsable técnico de facto, sin rol formal.
- ☐ Rol formal de seguridad dependiente del CIO.
- ☐ Rol formal de seguridad con reporte funcional a alta dirección.
- ☐ Función de seguridad con estructura propia y presencia en comités de riesgo.

P3.2.2 Porcentaje aproximado del **presupuesto de TI** dedicado a seguridad y gobierno de la información:

- ☐ < 3 % (seguridad como acto de fe).
- ☐ 3 – 5 %.
- ☐ 6 – 8 %.
- ☐ 9 – 12 %.
- ☐ > 12 % (seguridad como inversión estratégica).

4. Gestión de cambios de TI (BAI06)

Objetivo COBIT: **BAI06 – Managed IT Changes**.^[web:21]^[web:24]

4.1. Evaluación de seguridad en cambios

P4.1.1 Porcentaje aproximado de **cambios relevantes en sistemas críticos** que incluyen evaluación formal de impacto en ciberseguridad antes de su aprobación:

- ☐ 0 – 20 % (como mucho, rezamos).
- ☐ 21 – 40 %.
- ☐ 41 – 60 %.
- ☐ 61 – 80 %.
- ☐ 81 – 100 % (la temeridad no es estrategia).

P4.1.2 ¿Se realizan **pruebas de seguridad** (por ejemplo, pruebas de vulnerabilidades, revisiones de configuración) asociadas al proceso de cambios?

- ☐ No, o solo en casos excepcionales.
- ☐ Ocasionalmente, para cambios mayores.
- ☐ De forma habitual en cambios críticos.
- ☐ Integradas en el proceso estándar de cambios.
- ☐ Automatizadas como parte del pipeline de DevSecOps.

4.2. Impacto de cambios en incidentes

P4.2.1 En el último año, el porcentaje de incidentes de seguridad atribuibles a cambios mal gestionados ha sido:

- ☐ Desconocido (no se analiza la causa raíz).
- ☐ Menos del 10 %.
- ☐ 10 – 25 %.
- ☐ 26 – 50 %.
- ☐ Más del 50 % (los cambios mandan).

5. Servicios de seguridad (DSS05)

Objetivo COBIT: **DSS05 – Managed Security Services**. [web:17][web:21]

5.1. Monitorización y detección (SOC)

P5.1.1 ¿Dispone su organización de **capacidades de monitorización continua de seguridad** (SOC propio o externo)?

- ☐ No; confiamos en la providencia y en los logs sin mirar.
- ☐ Solo alertas básicas de dispositivos (firewalls, antivirus).
- ☐ SOC externo compartido o servicio MSSP básico.
- ☐ SOC interno o híbrido con correlación y casos de uso.
- ☐ SOC maduro con detección avanzada, inteligencia de amenazas y automatización.

P5.1.2 Tiempo medio de detección (MTTD) de incidentes significativos:

- ☐ No se mide / desconocido.
- ☐ Más de 1 mes.
- ☐ Entre 1 semana y 1 mes.
- ☐ Entre 24 horas y 1 semana.
- ☐ Menos de 24 horas (en la medida de lo humanamente posible).

5.2. Respuesta y remediación

P5.2.1 Tiempo medio de respuesta (MTTR) para contener incidentes significativos:

- ☐ No se mide / desconocido.
- ☐ Más de 1 semana.
- ☐ Entre 2 y 7 días.
- ☐ Entre 4 y 48 horas.
- ☐ Menos de 4 horas.

P5.2.2 Porcentaje de vulnerabilidades críticas resueltas dentro del plazo establecido por la política interna:

- ☐ 0 – 25 %.
- ☐ 26 – 50 %.
- ☐ 51 – 75 %.
- ☐ 76 – 90 %.
- ☐ 91 – 100 % (la utopía hecha proceso).

6. Continuidad del servicio (DSS04)

Objetivo COBIT: **DSS04 – Managed Continuity**. [web:27]

6.1. Planes y simulacros de continuidad

P6.1.1 ¿Dispone la organización de **Plan de Continuidad de Negocio (BCP)** y **Plan de Recuperación ante Desastres (DRP)** que incluyan escenarios de ciberincidentes?

- ☐ No se dispone de BCP/DRP.
- ☐ BCP/DRP en borrador, sin aprobación formal.
- ☐ BCP/DRP aprobados, sin pruebas recientes.
- ☐ BCP/DRP probados en los últimos 24 meses.
- ☐ BCP/DRP probados al menos anualmente, con lecciones aprendidas integradas.

P6.1.2 Frecuencia de **simulacros de ciber crisis** con participación de la dirección:

- ☐ Nunca (los simulacros solo ocurren en producción).
- ☐ Cada 3 años o menos.
- ☐ Bienal.
- ☐ Anual.
- ☐ Varias veces al año (según riesgos y cambios).

7. Monitorización, evaluación y mejora (MEA01-03)

Objetivos COBIT: **MEA01 – Performance and Conformance Monitoring**, **MEA02 – System of Internal Control**, **MEA03 – Compliance**. [web:17][web:34]

7.1. Cuadros de mando e indicadores

P7.1.1 ¿Dispone su organización de un **cuadro de mando de ciberseguridad** con indicadores cuantificados?

- ☐ No; se vive al día.
- ☐ Algunos indicadores dispersos, sin cuadro unificado.
- ☐ Cuadro básico con 3-5 indicadores.
- ☐ Cuadro estructurado con indicadores por dominio (riesgo, incidentes, cumplimiento, proyectos).
- ☐ Cuadro maduro, alineado con objetivos de negocio y revisado periódicamente.

P7.1.2 Periodicidad de revisión de indicadores de ciberseguridad:

- ☐ Ad hoc, ante incidentes o auditorías.
- ☐ Al menos una vez al año.
- ☐ Trimestral.
- ☐ Mensual.
- ☐ Semanal o continua.

7.2. Auditoría y acciones de mejora

P7.2.1 Frecuencia de auditorías internas o externas de ciberseguridad:

- ☐ Nunca.
- ☐ Menos de una vez cada 3 años.
- ☐ Cada 2-3 años.
- ☐ Anual.
- ☐ Varias veces al año (por normativa o riesgo).

P7.2.2 Porcentaje de **acciones correctivas** cerradas dentro del plazo comprometido:

- ☐ No se mide / desconocido.
- ☐ 0 – 40 %.
- ☐ 41 – 70 %.
- ☐ 71 – 90 %.
- ☐ 91 – 100 % (el plan se cumple, casi).

8. Madurez global (autoevaluación rápida)

Basado en la lógica de madurez COBIT 2019.[web:29][web:44]

P8.1 ¿Cómo valoraría el **nivel de madurez global** de su gestión de ciberseguridad, considerando procesos, personas, tecnología y cultura?

- ☐ Nivel 0 – Inexistente: ciberseguridad gestionada por el azar y la suerte.
- ☐ Nivel 1 – Inicial: prácticas reactivas, dependientes de héroes locales.
- ☐ Nivel 2 – Gestionado: procesos básicos definidos y aplicados de forma irregular.
- ☐ Nivel 3 – Definido: procesos estandarizados y comunicados, con cumplimiento razonable.
- ☐ Nivel 4 – Medido: procesos monitoreados con métricas y objetivos.
- ☐ Nivel 5 – Optimizado: mejora continua basada en datos y alineada con estrategia.

P8.2 (abierta) ¿Cuál considera que es la **mayor fortaleza** de su organización en ciberseguridad?

Texto libre:

P8.3 (abierta) ¿Y la **mayor debilidad o preocupación** actual?

Texto libre:

Fin del cuestionario. Gracias por su franqueza, incluso si duele un poco.